

Plantilla de Reporte Ejecutivo en PowerPoint — FAICP

Especificación completa de diapositivas para la presentación del IGM-FAICP al Consejo de Administración y al CISO

Versión: 1.0 — Abril 2026

Formato destino: Microsoft PowerPoint / Google Slides / Keynote

Duración estimada de la presentación: 20-30 minutos (modo ejecutivo) o 45-60 minutos (modo técnico ampliado)

Audiencias: Consejo de Administración, Comité de Riesgos, CISO, DPO, Reguladores (AESIA, CCN)

DISEÑO VISUAL GLOBAL

Paleta de Colores

Uso	Color	Hex
Color primario (fondo diapositivas clave)	Azul corporativo oscuro	#0D2137
Color secundario (acentos)	Azul IA	#1B6CA8
Alerta crítica	Rojo	#E03434
Alerta media	Naranja	#E8952A
Bien / Objetivo alcanzado	Verde	#2E8B57
Neutro / En progreso	Gris claro	#A9B4C2
Fondo diapositivas estándar	Blanco roto	#F8F9FA
Texto principal	Casi negro	#1A1A2E

Tipografía

Uso	Fuente	Tamaño
Títulos de sección	Montserrat Bold	36-44 pt
Títulos de diapositiva	Montserrat SemiBold	24-28 pt
Cuerpo de texto	Open Sans Regular	14-16 pt
Datos y métricas destacadas	Montserrat Bold	48-72 pt
Pies de página / notas	Open Sans Light	10 pt

(Alternativas: Calibri Bold para títulos, Calibri Regular para cuerpo — disponibles en todas las instalaciones de Office)

Elementos Fijos en Todas las Diapositivas

- Encabezado superior izquierdo: Logo de la organización (placeholder)
- Encabezado superior derecho: IGM-FAICP 2025-2026 | [Nombre organización] | Confidencial
- Pie de página izquierdo: Marcos: NIST IR 8596 · EU AI Act · GQM + PRAGMATIC
- Pie de página derecho: Número de diapositiva y fecha

ESTRUCTURA DE DIAPOSITIVAS (24 slides)

DIAPOSITIVA 01 — Portada

Tipo: Título de portada

Fondo: Color primario azul oscuro #0D2137

Elementos:

- **Línea superior (pequeño):** CONFIDENCIAL – [Clasificación según ENS si aplica]
- **Título principal (grande, blanco):** Informe de Postura de Ciberseguridad IA
- **Subtítulo:** Índice de Gobernanza y Madurez FAICP – IGM-FAICP
- **Bloque de datos clave (3 cifras en cajas azul claro):**
 - IGM-FAICP: [X.X]
 - Nivel: [EMERGENTE / DESARROLLADO / AVANZADO]
 - Indicadores Tier 1 en riesgo: [N]
- **Metadatos:** [Nombre organización] | [CCAA] | [Sector] | [Fecha]
- **Preparado por:** [CISO] | [Responsable de Riesgos IA]

Notas del presentador:

Esta presentación cubre los resultados de la evaluación IGM-FAICP, basada en el marco NIST IR 8596 (publicado dic. 2025), el EU AI Act y la metodología GQM + PRAGMATIC. El objetivo es proporcionar una visión ejecutiva de la postura de ciberseguridad IA de la organización, las brechas prioritarias y el plan de acción recomendado.

DIAPOSITIVA 02 — Contexto: Por qué ahora

Tipo: Diapositiva de contexto con datos de impacto

Fondo: Blanco roto

Título: El momento lo exige: la IA como vector de ataque y como objetivo

Layout: 3 columnas con iconos

Columna 1 — España 2025:

- Icono: Mapa de España
- 122.223 incidentes INCIBE (+26% YoY)
- Solo el 2% de empresas en nivel Mature
- 87% sufrió incidentes vinculados a IA

Columna 2 — Europa (ENISA ETL 2025):

- Icono: Escudo UE
- 80%+ de ingeniería social usa IA generativa
- Phishing: 60% de todos los vectores de intrusión
- Ransomware: sector industrial, 14.9% de reclamaciones

Columna 3 — El imperativo regulatorio:

- Icono: Balanza de justicia
- EU AI Act: sanciones hasta 30M€ o 6% vol. global
- NIS2: 10M€ o 2% de facturación global
- AESIA publicó 16 guías de cumplimiento (dic. 2025)

Fuentes (pie): Cisco CRI 2025 · INCIBE 2026 · ENISA ETL 2025 · EU AI Act 2024/1689

DIAPOSITIVA 03 — Marco de Evaluación Utilizado

Tipo: Explicación metodológica

Fondo: Blanco roto con banda lateral azul

Título: Metodología: GQM + PRAGMATIC sobre NIST IR 8596

Diagrama de capas (vertical, de arriba a abajo con flechas):

OBJETIVOS ESTRATÉGICOS NACIONALES ↓ GQM Nivel 1	← EU AI Act / ENS / NIS2 / INCIBE
OBJETIVOS ORGANIZATIVOS ↓ GQM Nivel 2	← Por función CSF 2.0
29 PREGUNTAS DE MEDICIÓN GQM ↓ Operacionalización	← Q-GV-01 ... Q-RC-03
29 INDICADORES IGM-FAICP ↓ Recogida de datos	← Evaluados con PRAGMATIC (9 criterios)
IGM-FAICP: ÍNDICE PONDERADO (1-5)	← Resultado ejecutivo

Leyenda de marcos:

- NIST IR 8596 (dic. 2025) · AI RMF 1.0 · EU AI Act · ENS · NIS2 · ISO/IEC 42001 · OWASP LLM Top 10 · MITRE ATLAS v5.5

DIAPOSITIVA 04 — Resultado IGM-FAICP (Portada de Resultados)

Tipo: Diapositiva de resultado principal — fondo azul oscuro

Fondo: Color primario #0D2137

Diseño:

- Número central enorme (blanco): [x.x] (valor del IGM-FAICP)
- Texto bajo el número: IGM-FAICP

- **Barra de progreso horizontal:** Escala 1-5 con marcadores en 1.5, 2.5, 3.5, 4.5
- **Indicador de posición** con triángulo de color correspondiente al nivel
- **Cuadro de nivel (color según nivel):** ● CRÍTICO / ● EMERGENTE / ● DESARROLLADO / ● AVANZADO / ● LÍDER
- **Tres comparativas (cajas pequeñas):**
 - vs. Media España: [X.X] | [+/- diferencia]
 - vs. Objetivo EU AI Act: 3.0 | Brecha: [X.X]
 - vs. Objetivo NIS2 OE: 3.5 | Brecha: [X.X]

DIAPPOSITIVA 05 — Perfil Radar de Madurez

Tipo: Diapositiva de visualización de datos

Título: Perfil de Madurez por Función FAICP

Elemento central: Gráfico de radar (spider chart) con 6 ejes

Ejes: GOBERNAR | IDENTIFICAR | PROTEGER | DETECTAR | RESPONDER | RECUPERAR
Escala: 0 a 5

Serie 1 (azul sólido): Mi Organización – valores reales
Serie 2 (naranja discontinuo): Objetivo Mínimo EU AI Act – 3.0
Serie 3 (verde punteado): Objetivo NIS2 Operadores Esenciales – 3.5

Tabla lateral:

Función	Puntuación	vs. Objetivo	Tendencia
GOBERNAR	[X.X]	[+/-]	[↑↓→]
IDENTIFICAR	[X.X]	[+/-]	[↑↓→]
PROTEGER	[X.X]	[+/-]	[↑↓→]
DETECTAR	[X.X]	[+/-]	[↑↓→]
RESPONDER	[X.X]	[+/-]	[↑↓→]
RECUPERAR	[X.X]	[+/-]	[↑↓→]

DIAPPOSITIVA 06 — Dashboard de los 29 Indicadores

Tipo: Heatmap / dashboard de indicadores

Título: Vista Completa: 29 Indicadores IGM-FAICP

Formato: Tabla compacta con código de color por puntuación

Código	Indicador (abreviado)	Tier	Puntuación	Estado
GV-01	Política IA	T1	[X]	● / ● / ● / ●
GV-02	Mapa dependencias	T1	[X]	...
... (todos los 29)				

Legenda de color:

- ● 1 = Crítico · ● 2 = Inicial · ● 3 = Definido · ● 4 = Gestionado · ● 5 = Optimizado

DIAPOSITIVAS 07-12 — Resultados por Función (6 diapositivas)

Una diapositiva por función: GOBERNAR, IDENTIFICAR, PROTEGER, DETECTAR, RESPONDER, RECUPERAR

Layout estándar por función:

Banda superior (color de función): Nombre de la función + puntuación media + Icono

Sección izquierda — Indicadores:

[Código] [Nombre] [Puntuación] [Barra de progreso]
[Código] [Nombre] [Puntuación] [Barra de progreso]
...

Sección derecha — Análisis:

- ● **Brecha crítica:** El indicador más bajo, su impacto y la acción recomendada
- ✓ **Fortaleza:** El indicador más alto
- 📅 **Próximo paso:** Una acción concreta con fecha

Pie de la diapositiva: Marcos normativos relevantes para esta función

DIAPOSITIVA 13 — Top 5 Brechas Críticas

Tipo: Diapositiva de análisis de brechas

Título: Las 5 Brechas que más urge cerrar

Formato: Lista de 5 items con diseño visual de tarjetas

Para cada brecha:

[Ranking] [CÓDIGO INDICADOR] [Nombre completo]
Puntuación actual: [X] → Objetivo: 3.5
Riesgo regulatorio: [Marco + Artículo + Sanción potencial]
Acción inmediata: [Descripción de la acción en una frase]
Inversión estimada: [Baja / Media / Alta]
Responsable: [Rol]

DIAPOSITIVA 14 — Análisis PRAGMATIC: Calidad de las Métricas

Tipo: Visualización de la calidad del marco de medición

Título: ¿Podemos confiar en nuestras métricas? Análisis PRAGMATIC

Sección izquierda — Distribución de puntuaciones PRAGMATIC:

- Gráfico de barras: Puntuación total PRAGMATIC por indicador (29 barras)
- Líneas de referencia: 21 (Recomendada) y 14 (Desestimar)

Sección derecha — Semáforo de criterios:

Criterio	Puntuación Media	Estado
Predictivo	[X.X]	●
Relevante	[X.X]	●
Accionable	[X.X]	●
Genuino	[X.X]	● ⚠ ATENCIÓN
Significativo	[X.X]	●
Preciso	[X.X]	●
Oportuno	[X.X]	●
Independiente	[X.X]	● ⚠ ATENCIÓN
Rentable	[X.X]	●

Nota destacada: "Los criterios Genuino e Independiente son los más bajos del marco. Se recomienda evaluación externa bienal para mitigar el sesgo de autoevaluación."

DIAPPOSITIVA 15 — Panorama de Amenazas IA (Contexto)

Tipo: Inteligencia de amenazas contextual

Título: El adversario se mueve a velocidad de máquina

Layout: 2×2 con 4 amenazas clave

Cuadrante 1 — Phishing LLM:

- Icono: Email con símbolo IA
- 80%+ de ingeniería social usa GenAI (ENISA ETL 2025)
- 54% de tasa de clic vs. 12% del phishing convencional
- Control crítico: IGM-PR-03 (Formación)

Cuadrante 2 — Agentes autónomos comprometidos:

- Icono: Robot con alerta
- 14 nuevas técnicas de ataque agéntico (MITRE ATLAS v5.5, oct. 2025)
- OWASP LLM06: Excessive Agency – nueva categoría 2025
- Control crítico: IGM-PR-06 (Agencia excesiva)

Cuadrante 3 — Deepfakes ejecutivos:

- Icono: Cara con máscara digital
- Incidentes deepfake +680% en 2025
- Business Voice Compromise: nuevo vector de BEC
- Control crítico: IGM-PR-03 (Formación) + IGM-RS-01 (Playbooks)

Cuadrante 4 — Envenenamiento de modelos:

- Icono: Modelo con calavera
- OWASP LLM04: Data & Model Poisoning
- Primeros casos documentados en producción (ENISA 2025)
- Control crítico: IGM-ID-01 (AI-BOM) + IGM-PR-04 (Protección datos)

DIAPOSITIVA 16 — Comparativa Territorial (España y CCAA)

Tipo: Benchmarking territorial

Título: Posición en el Ecosistema: España y [CCAA de la organización]

Sección izquierda — Mapa de España con heatmap:

Mapa de CCAA con color de intensidad según nivel de madurez estimado

Sección derecha — Tabla comparativa:

Ámbito	IGM-FAICP	AI Fortification Mature	Referencia
Mi organización	[X.X]	—	Este informe
España media	~1.4	7%	Cisco CRI 2025
Media global	~1.4	7%	Cisco CRI 2025
Objetivo EU AI Act	3.0	—	EU AI Act 2024/1689
Objetivo NIS2 OE	3.5	—	NIS2 2022/2555

DIAPOSITIVA 17 — Plan de Acción: Hoja de Ruta

Tipo: Hoja de ruta temporal

Título: Plan de Mejora IGM-FAICP: De [X.X] a [Objetivo] en 18 meses

Diagrama de Gantt simplificado (3 fases):

FASE 1 — Meses 1-3 (Indicadores Tier 1 Críticos):

- IGM-GV-01: Política IA aprobada por dirección
- IGM-ID-01: AI-BOM completo
- IGM-PR-01: IAM para sistemas IA
- IGM-RS-01: Playbooks IA desarrollados
- IGM-RS-03: Plazos de notificación conocidos
- IGM-RC-01: Planes de recuperación con rollback
- **Meta de Fase 1:** IGM-FAICP $\geq$ 2.5

FASE 2 — Meses 4-9 (Consolidación Preventiva):

- Completar indicadores Gobernar, Identificar y Proteger
- Iniciar programa de formación diferenciado por rol
- Implementar monitorización de APIs IA y model drift
- **Meta de Fase 2:** IGM-FAICP $\geq$ 3.0

FASE 3 — Meses 10-18 (Capacidades Avanzadas de Detección y Respuesta):

- SOC con capacidades MITRE ATLAS
- Ejercicios de respuesta a incidentes IA
- Evaluación externa y benchmarking sectorial
- **Meta de Fase 3:** IGM-FAICP ≥ 3.5

DIAPOSITIVA 18 — ROI de la Inversión en Ciberseguridad IA

Tipo: Modelo financiero simplificado

Título: El caso de negocio: por qué la inversión en IGM-FAICP es rentable

Sección izquierda — Escenarios:

Escenario	Inversión	Reducción Incidentes	ROSI	Payback
Conservador	[€]	30%	[%]	[meses]
Base	[€]	50%	[%]	[meses]
Optimista	[€]	70%	[%]	[meses]

Sección derecha — Coste del no-hacer:

- Multa EU AI Act potencial (si incidente grave): hasta [€] calculado
- Multa NIS2 potencial (si incidente significativo): hasta [€] calculado
- Coste promedio de incidente IA (IBM 2025): 4.45M USD
- Coste reputacional (difícil de cuantificar — no incluido)

DIAPOSITIVA 19 — Mapeo Normativo: Obligaciones y Plazos

Tipo: Tabla de cumplimiento

Título: Qué nos obliga la ley y en qué plazo

Tabla de obligaciones críticas:

Obligación	Marco	Artículo	Plazo	Estado	Riesgo
Registro sistemas IA alto riesgo en EUDB	EU AI Act	Art. 49	Inmediato	[✓/●]	Hasta 30M€
Sistema de gestión de riesgos IA	EU AI Act	Art. 9	Inmediato	[✓/●]	Hasta 30M€
Notificación incidente NIS2 (alerta)	NIS2	Art. 23.1.a	24 horas	[✓/●]	Hasta 10M€
Notificación incidente NIS2 (formal)	NIS2	Art. 23.1.b	72 horas	[✓/●]	Hasta 10M€
Notificación incidente IA grave a AESIA	EU AI Act	Art. 73	15 días hábiles	[✓/●]	Hasta 30M€
Notificación brecha RGPD a AEPD	RGPD	Art. 33	72 horas	[✓/●]	Hasta 20M€
Certificación ENS (AAPP)	ENS	RD 311/2022	Según categoría	[✓/●]	Disciplinaria

DIAPOSITIVA 20 — Responsabilidades: Quién Hace Qué

Tipo: Matriz RACI simplificada

Título: Gobernanza del Plan de Mejora: Roles y Responsabilidades

Actividad	Consejo/ Dirección	CISO	DPO	Equipo Seguridad IA	Auditor Interno
Aprobar política IA	A	R	C	I	I
Calcular IGM-FAICP	I	A	C	R	V
Desarrollar AI-BOM	I	A	C	R	V
Gestionar proveedores IA	C	A	C	R	V
Aprobar inversión mejora	A	R	I	I	I
Notificar a AESIA/INCIBE	I	A/R	R	R	I
Revisar decisiones sistema comprometido	C	A	R	R	V

Leyenda: R=Responsable · A=Aprobador · C=Consultado · I=Informado · V=Verificador

DIAPPOSITIVA 21 — Próximos Pasos Inmediatos (30 días)

Tipo: Call to action ejecutivo

Título: Lo que debe pasar en los próximos 30 días

Formato: 5 acciones concretas con semáforo de urgencia:

● URGENTE (Semana 1-2):

- ☐ Designar formalmente el Responsable de Ciberseguridad IA (IGM-GV-05)
- ☐ Iniciar el inventario AI-BOM urgente con herramientas automáticas de descubrimiento (IGM-ID-01)
- ☐ Verificar que el equipo conoce los plazos de notificación NIS2 y EU AI Act (IGM-RS-03)

● IMPORTANTE (Semana 3-4):

- ☐ Convocar al Comité de Dirección para aprobar la Política de Ciberseguridad IA (IGM-GV-01)
- ☐ Asignar presupuesto para el Plan de Mejora IGM-FAICP Fase 1

Celda de decisión destacada:

DECISIÓN SOLICITADA AL CONSEJO:
Aprobación del Plan de Mejora IGM-FAICP
Inversión Fase 1 (90 días): [€ calculado en HOJA 5]
ROI Estimado: [%] en [meses]

DIAPOSITIVA 22 — Preguntas Frecuentes del Consejo

Tipo: FAQ anticipado

Título: Las 5 preguntas que suelen hacer el Consejo y sus respuestas directas

Pregunta	Respuesta (una línea)
"¿Somos legalmente responsables si un sistema de IA falla?"	Sí, bajo EU AI Act Art. 9 y 72. La responsabilidad es de quien despliega.
"¿Puede la IA protegernos de la propia IA?"	Sí — pero solo si se gobierna adecuadamente (IGM-DE-01/02).
"¿Qué pasa si no hacemos nada?"	Probabilidad de incidente grave: 87% en 12 meses (Cisco CRI 2025). Multa potencial: hasta 30M€.
"¿Cuánto cuesta y cuánto tardamos en estar seguros?"	[Insertar cifras de HOJA 5]. Nivel 3.0 en 9 meses con inversión de [€].
"¿Cómo sabemos que estamos mejorando?"	IGM-FAICP revisado semestralmente; seguimiento mensual de KPIs del plan de acción.

DIAPOSITIVA 23 — Glosario Ejecutivo

Tipo: Referencia rápida

Título: Términos clave sin jerga innecesaria

Término	Definición ejecutiva (una línea)
IGM-FAICP	Nuestra puntuación global de ciberseguridad IA, de 1 (crítico) a 5 (líder)
AI-BOM	El inventario completo de todos los sistemas de IA que usamos, como un plano de planta
Prompt injection	Un atacante manipula un chatbot IA dándole instrucciones ocultas en el texto
Model drift	El sistema de IA empieza a dar respuestas incorrectas sin que nadie lo note
Agente IA	Un sistema de IA que puede actuar en el mundo (enviar emails, ejecutar código) de forma autónoma
Shadow AI	Herramientas de IA que los empleados usan sin aprobación del departamento de TI
MTTR-AI	Cuánto tardamos en solucionar un incidente de ciberseguridad en un sistema de IA
AESIA	La Agencia Española que supervisa el cumplimiento del EU AI Act (sede en A Coruña)

DIAPPOSITIVA 24 — Cierre y Contacto

Tipo: Diapositiva de cierre — fondo azul oscuro

Título (grande, blanco): "El mapa no es el territorio. Pero sin mapa, todos los caminos llevan al riesgo."

Información de contacto del equipo:

[Nombre del CISO] – ciso@[empresa].es
[Nombre del DPO] – dpo@[empresa].es
[Nombre del Responsable de Seguridad IA] – aisg@[empresa].es

Recursos de referencia:

- AESIA: aesia.digital.gob.es
- INCIBE (línea de ayuda 24/7): 017
- CCN-CERT: ccn-cert.cni.es
- NIST AI Frameworks: airc.nist.gov

Marcos utilizados:

NIST IR 8596 (dic. 2025) · NIST AI RMF 1.0 · EU AI Act 2024/1689
ENS RD 311/2022 · NIS2 2022/2555 · ISO/IEC 42001:2023
OWASP LLM Top 10 2025 · MITRE ATLAS v5.5 (2026)
Cisco Cybersecurity Readiness Index 2025
ENISA Threat Landscape 2025 · WEF Global Cybersecurity Outlook 2025
INCIBE Informe de Incidentes 2025

APÉNDICE: DIAPOSITIVAS TÉCNICAS OPCIONALES (para presentación ampliada)

AT-01 — Detalle PRAGMATIC por Función

Tabla expandida de los 29 indicadores con todas las puntuaciones P-R-A-G-M-Ac-T-I-C y totales.

AT-02 — Mapeo Normativo por Artículo

Reproductor de la tabla completa del fichero (d) Mapeo Normativo para auditorías regulatorias.

AT-03 — Arquitectura Técnica de Monitorización Propuesta

Diagrama de arquitectura de la solución de monitorización IA recomendada (SIEM + MLOps + AI Gateway).

AT-04 — Metodología de Cálculo IGM-FAICP

Fórmula matemática del IGM-FAICP con justificación de pesos y ejemplos de cálculo.

AT-05 — Comparativa de Marcos Internacionales

Tabla de equivalencia entre NIST IR 8596, MITRE ATLAS, OWASP LLM Top 10, ISO 42001 y EU AI Act.

Instrucciones de Personalización

Datos a Reemplazar por la Organización

Antes de presentar, sustituir todos los elementos marcados con [X.X], [N], [€] o [nombre] con:

1. IGM-FAICP y puntuaciones: Extraídos de la HOJA 4 de la plantilla Excel (fichero e)
2. Brechas críticas: De la HOJA 6 "Plan de Acción" de la plantilla Excel
3. Inversiones y ROI: De la HOJA 5 "ROI Ciberseguridad IA"
4. Nombre, CCAA, sector: De la HOJA 2 "Datos Organización"
5. Estado de cumplimiento normativo (✓/●): Evaluación jurídica propia

Adaptación por Audiencia

Audiencia	Diapositivas recomendadas	Duración
Consejo de Administración	01, 02, 04, 05, 13, 18, 19, 21, 22, 24	20-25 min
Comité de Riesgos	01-06, 13-14, 17-21, 24	35-40 min
CISO / Equipo Técnico	Presentación completa + apéndices técnicos	60-75 min
AESIA / Regulador	01, 03, 06, 07-12, 14, 19, 24 + AT-02	30-40 min